ENUMERATION - Detailed Notes

What is Enumeration?

1. **Enumeration** is the second major step in the hacking methodology, following **Scanning** and preceding **Exploitation**.
2. It is the crucial stage where a hacker or penetration tester extracts specific, detailed information about users, groups, shares, and services from a target system or network.
3. While **Scanning** answers *what* services are running (e.g., "Port 80 is open"), **Enumeration** answers *who* and *how* those services are configured (e.g., "The web server is running as user 'admin' and has a directory named 'backups' that lists its contents").

What information does enumeration reveal?

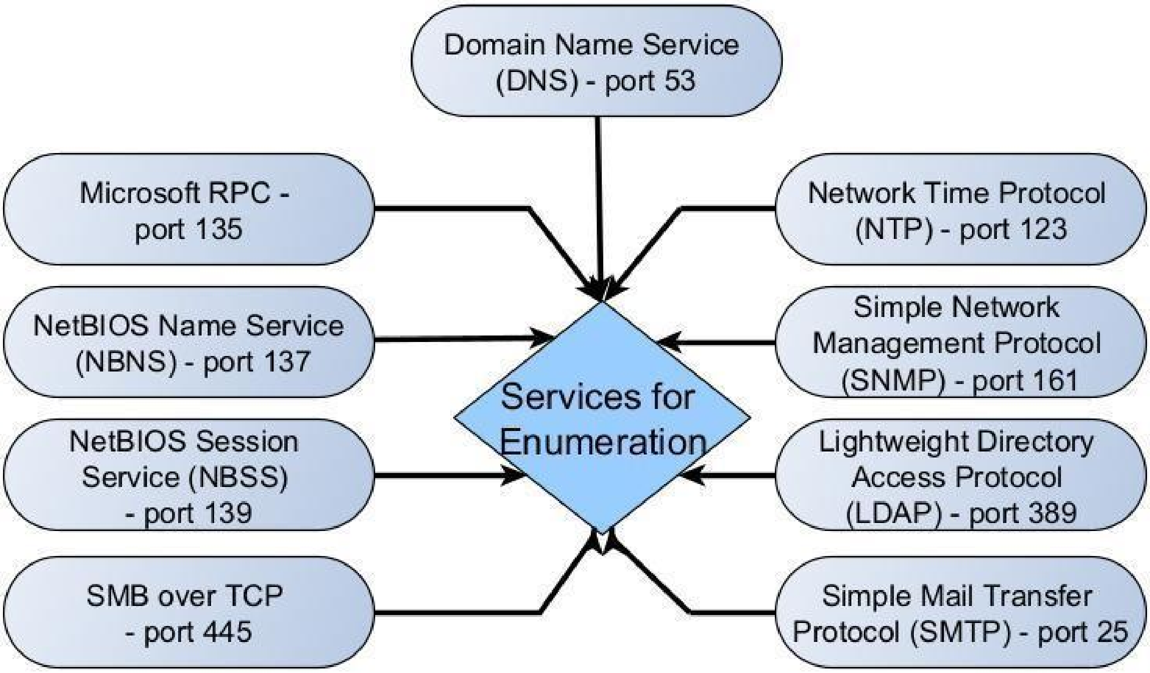
4. Enumeration can reveal valuable information like Network shares, usernames and passwords, version of the application running, users and groups, machine names, service settings and other network resources.

Purpose of Enumeration

- **User and Group Discovery:** Identifying valid **usernames** and **group names** (e.g., 'administrator', 'domain users').
- **Resource Mapping:** Finding accessible **network shares** (folders), printers, and file system details.
- **Service Deep Dive:** Extracting configuration details, such as **DNS records**, **SNMP community strings**, and specific application banners.
- **Weakness Identification:** Discovering misconfigurations, default credentials, or vulnerable service version details that can be directly exploited.

Which services can be enumerated ?

Fig: Popular services on which enumeration need to be performed



Although all services running on the target system can be enumerated upon, there are some specific services which are regularly enumerated to retrieve useful information. They are,

1. **DNS (Port 53)**
2. **Microsoft RPC (Port 153)**
3. **NetBIOS Name Service (NBNS) (Port 137)**
4. **NetBIOS Session Service (SMB over NetBIOS)**
5. **SMB Over TCP (Port 445)**
6. **Network Time Protocol (NTP) (Port 123)**
7. **Simple Network Management Protocol (SNMP) (Port 161)**
8. **Lightweight Directory Access Protocol (LDAP) (Port 389)**
9. **Simple Mail Transfer Protocol (SMTP) (Port 25)**

1. DNS (Domain Name System)

- Port: 53
- Transport: UDP (Standard queries) and TCP (Zone transfers, large responses).
- Function: Translates human-readable domain names (e.g., google.com) into computer-readable IP addresses. This is essential for all internet communication.
- Hacking/Enumeration Relevance: Misconfigured DNS servers can allow a Zone Transfer (AXFR query), which provides an attacker with a full list of all hostnames and IP addresses within a domain.

2. Microsoft RPC (Remote Procedure Call)

- Port: 135 (TCP/UDP) is the Endpoint Mapper. The specific RPC service communication uses high dynamic ports (typically in the 49152–65535 range).
- Transport: TCP and UDP.
- Function: A fundamental mechanism in Windows that allows a program on one computer to request a service from a program on another computer without having to understand the network details. It is the basis for many services, including directory services and file sharing.
- Hacking/Enumeration Relevance: Port 135 is scanned to find which dynamic ports are being used by specific, potentially vulnerable RPC services. It is a frequent target for remote exploitation on Windows systems.

3. NetBIOS Name Service (NBNS)

- Port: 137
- Transport: UDP
- Function: Used in older Windows networks (pre-dominantly WINS) for name resolution. It resolves a 16-character NetBIOS name to an IP address on the local network.
- Hacking/Enumeration Relevance: It can be abused in NBNS Spoofing/Poisoning attacks, where an attacker intercepts and responds to name resolution requests to trick a victim machine into sending authentication hashes to the attacker.

4. NetBIOS Session Service (SMB over NetBIOS)

- Port: 139
- Transport: TCP
- Function: Establishes a session-layer connection necessary to carry the Server Message Block (SMB) protocol over NetBIOS. This facilitated legacy file and printer sharing on older Windows versions.
- Hacking/Enumeration Relevance: While largely replaced by SMB over TCP (Port 445), it is still used for enumeration of users, groups, and accessible shares if legacy services are running.

5. SMB Over TCP (Server Message Block)

- Port: 445
- Transport: TCP
- Function: The modern and standard protocol for file and printer sharing, as well as remote administration, in current Windows (and other OS via Samba). It runs the SMB protocol directly over TCP.
- Hacking/Enumeration Relevance: Highly critical and frequently targeted. Vulnerable to remote code execution exploits (like EternalBlue) and deep enumeration via anonymous connections (Null Sessions) to find users and shares.

6. Network Time Protocol (NTP)

- Port: 123
- Transport: UDP
- Function: Used to accurately synchronize the clocks of all computer systems on a network. Accurate time is crucial for security mechanisms like Kerberos authentication and for accurate forensic logging.
- Hacking/Enumeration Relevance: NTP can be leveraged for DDoS reflection and amplification attacks by sending a small request to a server that then sends a massive reply to the victim.

7. Simple Network Management Protocol (SNMP)

- Port: 161 (Agent listening for requests) and 162 (Trap receiver for device alerts).
- Transport: UDP
- Function: Used for monitoring, managing, and collecting status data from network devices (routers, servers, printers). Management information is accessed using credentials called community strings.
- Hacking/Enumeration Relevance: If default community strings (like 'public' for read-only) are not changed, attackers can retrieve vast amounts of sensitive system information, including user lists, running processes, and configuration details.

8. Lightweight Directory Access Protocol (LDAP)

- Port: 389 (Standard) and 636 (LDAPS for secure/encrypted access).
- Transport: TCP and UDP
- Function: An application protocol used to access and manage distributed directory information services, such as Microsoft Active Directory. It stores organizational, user, group, and policy data.
- Hacking/Enumeration Relevance: Enumeration allows attackers to map the entire organization's structure, identify administrative accounts, and determine group memberships—all critical steps for privilege escalation and lateral movement.

9. Simple Mail Transfer Protocol (SMTP)

- Port: 25 (Server-to-server relay) and 587 (Client submission).
- Transport: TCP
- Function: The primary protocol used for sending (relaying) email messages between mail servers.
- Hacking/Enumeration Relevance: If misconfigured, SMTP servers may respond to commands like VRFY (verify user) or EXPN (expand mailing list), allowing an attacker to quickly enumerate valid usernames on the system.

Common Tools use for Enumeration

1. Enum4linux

- **Function:** A Linux tool primarily used to enumerate information from Windows and Samba hosts using the **SMB** and **NetBIOS** protocols. It automates the process of querying for users, groups, shares, and password policies.

2. Nmap Scripting Engine (NSE)

- **Function:** Nmap's powerful feature that extends its capabilities far beyond just port scanning. NSE scripts are frequently used for enumeration across various protocols (e.g., smb-enum-users, smtp-enum-users, snmp-info) to extract specific details like usernames or configuration data.

3. Dig and Nslookup

- **Function:** Standard command-line utilities for querying **DNS** servers. They are the primary tools used to manually attempt **Zone Transfers** or find specific DNS records.

4. snmp-check

- **Function:** A dedicated tool used to query devices running **SNMP**. It checks for well-known **community strings** (like 'public' or 'private') and, upon success, extracts detailed information about the system and its configuration from the MIB.

5. Telnet

- **Function:** A basic network protocol client used for interactive communication with network services. It is often used for manual **SMTP enumeration** by connecting to Port 25 and issuing commands like VRFY (verify) to test user existence.

6. Metasploit

- **Function:** While primarily an exploitation framework, Metasploit contains a large library of powerful **auxiliary modules** specifically designed for automated enumeration across numerous protocols (SMB, FTP, database services, etc.).